

Data Privacy Policy

GDPR compliance and data handling procedures at Acme Corp.

Data Classification

Level	Definition	Examples
Public	No harm if disclosed	Marketing materials, blog posts
Internal	Internal use only	Engineering docs, internal dashboards
Confidential	Limited access	Customer contracts, financial data
Restricted	Strictly controlled	PII, credentials, health data

Personally Identifiable Information (PII)

PII includes: name, email, phone, address, IP address, device IDs, payment info, and any data that can identify a natural person.

Handling Rules

- **Storage** — PII must be encrypted at rest (AES-256). Use our key management service, not application-level encryption.
- **Retention** — Customer PII is retained for the duration of the contract plus 90 days. Delete after that.
- **Access** — Only employees with a direct business need may access PII. Access is logged and audited quarterly.
- **Transfer** — PII may not be transferred outside the EU/EEA without a Data Processing Agreement (DPA) in place.

Data Breach Procedure

1. **Detect** — Any suspected breach must be reported to security@acme.internal immediately.
2. **Contain** — Isolate affected systems. Do not delete logs.
3. **Assess** — Security team determines scope within 4 hours.
4. **Notify** — If personal data is involved, notify the DPA within 72 hours (GDPR requirement). Notify affected users within 48 hours of confirmation.
5. **Remediate** — Fix the root cause. Post-mortem within 1 week.

User Rights (GDPR)

Users may request:

- **Access** — What data we hold about them.
- **Rectification** — Correct inaccurate data.
- **Erasure** — Delete their data (“right to be forgotten”).
- **Portability** — Export their data in machine-readable format.

All requests must be fulfilled within 30 days. Route requests to privacy@acme.internal.